

Termin 3 – Resilienz-Architekturen

Redundanz • Diversität • Wiederherstellbarkeit • Adaptivität

Prof. Dr. Dirk Loomans

29. September 2026

Vorlesungsskript • Grundlagen der Resilienz • Cyber Security Management (B.Sc.), 1. Semester • Hochschule Mainz

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Leitfrage

Wie werden Systeme so gebaut, dass sie Störungen überstehen und kontrolliert wiederhergestellt werden können – im Rechenzentrum, in der Cloud und hybrid?

Lernziele

Nach diesem Termin können Studierende

- die vier technischen Resilienzprinzipien erklären und voneinander abgrenzen,
- Redundanz in On-Prem- und Cloud-Umgebungen vergleichen,
- Single Points of Failure (SPOFs) in hybriden Architekturen erkennen,
- jedem SPOF ein Gegenprinzip und eine realistische Maßnahme zuordnen.

Fachinhalte

Von der Messung zur Gestaltung

Termin 2 hat gezeigt: Resilienz ist messbar (RTO, RPO, MTTR), normativ verankert (NIST, ISO/IEC 27031, BSI 200-4), und Hybridwelten erhöhen die Komplexität. Messung allein reicht nicht – **Resilienz muss im Design entstehen**. Die vier Prinzipien gelten unabhängig von Technologie-Stacks, Betriebsformen und Anbietern:

1. **Redundanz** – keine einzelnen Bruchpunkte
2. **Diversität** – keine gemeinsamen Fehlerquellen
3. **Wiederherstellbarkeit** – geübte, getestete Rückkehrfähigkeit
4. **Adaptivität** – Systeme reagieren dynamisch statt statisch

Prinzip 1: Redundanz

Redundanz ist die vorsätzliche Mehrfachvorhaltung kritischer Ressourcen, damit einzelne Komponenten ausfallen können, ohne dass das Gesamtsystem seine Funktion verliert.

On-Premises	Cloud
Dual Power Feed, USV, Diesel-Backup	Multi-AZ-Deployment in einer Region
redundante Core-Switches, doppelte ISP-/MPLS-Wege	Load Balancing und Auto-Scaling
Cluster (z. B. SQL AlwaysOn, VMware HA)	Cross-Region-Failover
zweites Rechenzentrum als Cold/Warm/Hot Standby	

Die Ausfallsicherheit steigt mit dem Grad der Entkopplung: **Zwei USVs im gleichen Brandabschnitt sind Redundanz ohne Isolation.** On-Prem wird Redundanz kapazitiv vorgehalten (CapEx), in der Cloud ist sie elastisch konsumierbar (OpEx). Resilienz wird dadurch kaufbar, aber nicht automatisch vorhanden – sie muss im Architekturentwurf aktiviert werden.

Grenzen: Redundanz schützt nur gegen komponentielle Ausfälle, nicht gegen logische oder Konfigurationsfehler, konzertierte Angriffe (Ransomware, Wiper), gemeinsame Abhängigkeiten (etwa ein zentrales AD) und nicht getestete Umschaltprozesse. Redundanz ohne getestete Umschaltung ist nur eine strukturelle Reserve.

Prinzip 2: Diversität

Diversität vermeidet gemeinsame Fehlerursachen (Common Mode Failures). Redundante, aber homogene Systeme teilen dieselben Schwachstellen und können gleichzeitig scheitern.

- **Komponentendiversität:** unterschiedliche HSMs, CA-Stacks, Backup-Mechanismen
- **Lieferantendiversität:** Multi-Vendor-Firewalls, Multi-Cloud, verschiedene Identity-Provider
- **Technologiediversität:** unterschiedliche Betriebssysteme, Container und VM, heterogene Storage-Systeme

Diversität reduziert die Wahrscheinlichkeit synchroner Ausfälle, verringert Lieferkettenabhängigkeit und bricht Komplexitätskopplungen. Supply-Chain-Angriffe wie SolarWinds (2020) zeigen, dass Homogenität ein systemischer Verstärker ist; ein diverser Stack wirkt wie ein Brandschott. Diversität erhöht Betriebskosten (Know-how, Verträge, Integration), ist aber eine Versicherung gegen seltene Ereignisse mit großer Wirkung.

Prinzip 3: Wiederherstellbarkeit

Ein System ist nicht resilient, weil es redundante Daten besitzt, sondern weil es nach einem Störfall kontrolliert und innerhalb akzeptabler Grenzwerte wieder in Betrieb gehen kann.

- **Recovery ist eine Fähigkeit, kein Dokument.** DR-Tests sind wichtiger als DR-Pläne; ein ungeübter Plan ist funktional kein Plan.
- **Automatisierung:** Infrastructure as Code für reproduzierbare Neuaufbauten, Snapshots und Immutabile Backups gegen Datenverlust, Runbooks und SOAR gegen lange MTTR, Failover-Szenarien gegen lange RTO.
- **Backup ≠ Recovery:** Ein Backup ist ein Zustand, Recovery ein Prozess mit Zeit- und Qualitätszielen. Ein ungetestetes Backup ist eine Hypothese.
- RTO und RPO sinnvoll, nicht maximal festlegen.

Die häufigsten Resilienzversagen entstehen nicht aus fehlenden Daten, sondern aus fehlgeschlagenen Wiederanläufen: ungeprüfte Abhängigkeiten, mangelhafte Automatisierung, fehlende Rollenklärung.

Prinzip 4: Adaptivität

Stabilität hält einen Zustand; Resilienz rekonfiguriert sich unter Störung ohne Funktionsverlust als Ganzes.

- Auto-Scaling statt fester Kapazität
- Graceful Degradation – nicht alles oder nichts
- Feature Flags, Circuit Breaker, Canary Releases zur kontrollierten Drosselung
- Traffic Shifting, Anycast, Failover-Logik
- Chaos Engineering als Testmethode (z. B. Netflix „Chaos Monkey,,): Resilienz entsteht nicht durch Erwartung, sondern durch Exposition.

Adaptivität ist ein Multiplikator, kein Ersatz. Systeme, die nur adaptiv sind, aber auf einem gemeinsamen Identitäts- oder Datenknoten aufbauen, passen sich lediglich innerhalb der Fragilität an.

Hybridarchitekturen

Kriterium	On-Prem	Cloud
Redundanz	Hardware-Duplikation	Region-/AZ-Abstraktion
Diversität	manuell geplant	pro Provider oder Multi-Cloud
Recovery	Runbooks und Menschen	IaC und Automatisierung
Adaptivität	begrenzt	nativ (Scaling, Traffic-Shift)

Potenziale: Workload-Verlagerung zwischen On-Prem und Cloud, Diversifizierung der Ausführungsumgebung, Entkopplung über APIs, Message-Bus und Asynchronität, Resilienz „as a Service,, (Multi-AZ, Geo-Replikation).

Hybrid-SPOFs: Identity-Systeme (AD/IdP) als globaler Fail-Knopf, Netzwerk-Transit (VPN/SD-WAN) als Engpass, zentrale Orchestrierung und CI/CD als Single Control Layer, Echtzeit-Datenkopplung mit engen Synchronisationszwängen. Ein System kann funktional verteilt, aber steuerungstechnisch monolithisch und damit fragil sein.

Hybrid verlangt doppelte Resilienzlogik: Cloud-Resilienz ersetzt nicht RZ-Resilienz, und die SPOF-Suche muss über Systemgrenzen hinweg erfolgen (Identity, Netzwerk, Control Plane). Hybrid erhöht den Suchraum der Fragilität und zugleich den Werkzeugkasten der Resilienz.

Häufige Irrtümer

- „Wir sind in der Cloud, also sicher.,“
- „Backup = Resilienz.,“
- „Cluster = Disaster Recovery.,“
- „Nie getestet, aber dokumentiert.,“
- „Single-Cloud,, mit „Multi-Region“ verwechselt.

Fallbeispiel: Hybrid-Störung

ERP läuft On-Prem, Reporting und Analytics laufen in der Cloud. Ein On-Prem-Domain-Controller wird durch Ransomware kompromittiert. Die Cloud-Analytics bleibt technisch verfügbar – aber niemand kann sich anmelden.

- Was bleibt funktional und warum?
- Wo sitzt der eigentliche SPOF?
- Welche Maßnahme hätte die Resilienz verbessert?

Normativer Bezug

NIST SP 800-160 Vol. 2 behandelt Diversität und Redundanz als Architekturprinzipien des Resilience Engineering [1]. ISO/IEC 27031 und der BSI-Standard 200-4 fordern Recovery-Tests, regelmäßige Übungen und Lessons-Learned-Zyklen statt bloßer Planexistenz [2], [3]. ENISA betont Diversität als Gegenmittel gegen Supply-Chain-Risiken.

Übung: SPOFs identifizieren und zuordnen

Gruppen, 15–30 Minuten. Wählen Sie ein reales System (Cloud-Drive, Banking-App, Campus-E-Mail, Smart-Home-Plattform, Krankenhaus-IT).

1. Identifizieren Sie mindestens drei Single Points of Failure (z. B. IdP, Netzwerk-Backbone, zentrales Storage, CI/CD-Pipeline).
2. Ordnen Sie jedem SPOF ein Prinzip zu, das ihn adressiert: Redundanz, Diversität, Wiederherstellbarkeit oder Adaptivität.
3. Formulieren Sie pro SPOF eine realistische Maßnahme – keine Wunschlösung.

Ergebnis: eine Folie oder ein 5-Punkte-Statement pro Gruppe. Resilienz beginnt nicht mit Technik, sondern mit dem Benennen des Bruchpunkts.

Prüfungsrelevante Leitfragen

- Erklären Sie den strukturellen Unterschied zwischen Redundanz und Diversität.
- Warum ist Recovery eine Fähigkeit und kein Plan?
- Nennen Sie zwei typische Hybrid-SPOFs und ordnen Sie je ein Gegenprinzip zu.
- Welche Rolle spielt Adaptivität im Unterschied zu Redundanz?

Merksätze: Resilienz entsteht im Design, nicht im Incident. Redundanz, Diversität, Recovery und Adaptivität bilden den technischen Kern. Hybrid erhöht Chancen und Risiken. Fähigkeit schlägt Dokumentation.

Vor- und Nachbereitung

Ausblick Termin 4: Bedrohungen und Resilienzstrategien – Mapping von Angriffen auf Widerstands- und Recovery-Muster.

Material aus dem Archiv

03 Resilienz Architekturen/03_Resilienz-Architekturen.pdf, Grundlagen der Resilienz 3.pdf (Skript) und Glossar Resilienz.pdf.

Bibliografie

- [1] R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, und R. McQuaid, „Developing Cyber-Resilient Systems: A Systems Security Engineering Approach“, NIST Special Publication 800-160 Vol. 2 Rev. 1, Dez. 2021. doi: [10.6028/NIST.SP.800-160v2r1](https://doi.org/10.6028/NIST.SP.800-160v2r1).
- [2] „ISO/IEC 27031:2025 Cybersecurity – Information and communication technology readiness for business continuity“. [Online]. Verfügbar unter: <https://www.iso.org/standard/27031>
- [3] „BSI-Standard 200-4: Business Continuity Management“. Bonn, Mai 2023.